



XUNTA DE GALICIA
CONSELLERÍA DE EDUCACIÓN
E ORDENACIÓN UNIVERSITARIA

I.E.S. ARMANDO
COTARELO VALLEDOR



Curso 2024-2025

Implementación de un sistema IDS/IPS.

PAULA FERNÁNDEZ FERNÁNDEZ

Proxecto final do Ciclo Formativo de Técnico Superior en Administración de Sistemas Informáticos
en Rede. Curso 2024-2025. IES ARMANDO COTARELO VALLEDOR

Índice

1. OBXECTIVOS E ALCANCE DO PROXECTO.	4
1.1. EXPLICACIÓN DE IDS/IPS.	4
1.1.1. <i>Para que serve un IDS/IPS?</i>	4
1.1.2. <i>A importancia da seguridade actualmente.</i>	4
1.2. EXPLICACIÓN DE SURICATA.	4
1.2.1. <i>Características principais:</i>	5
1.2.2. <i>¿Por que escoller Suricata e non outra ferramenta?</i>	5
1.2.3. <i>Vantaxes:</i>	5
1.2.4. <i>Inconvenientes:</i>	5
1.3. DESCRICIÓN DO PRODUTO E SERVIZO.	5
1.4. USUARIOS DESTINADOS.....	5
1.5. ALCANCE DO PROTOTIPO.....	6
1.6. MOTIVACIÓN DO PROXECTO.	6
2. ESTUDO ECONÓMICO.	6
2.1. IDEA DE NEGOCIO.	6
2.1.1. <i>Valor engadido e utilidade.</i>	6
2.1.1.1. Democratización de tecnoloxía avanzada.....	6
2.1.1.2. Sistema de notificacións móbiles vía Telegram	6
2.1.1.3. Modelo híbrido servizo – produto.	7
2.1.1.4. Especialización local.....	7
2.1.1.5. Soporte técnico especializado 24/7.	7
2.1.2. <i>Produtos aumentados.</i>	8
2.2. XUSTIFICACIÓN DA IDEA.	8
2.3. ANÁLISE DAFO.....	8
2.3.1. <i>Debilidades.</i>	8
2.3.2. <i>Ameazas.</i>	8
2.3.3. <i>Fortalezas.</i>	8
2.3.4. <i>Oportunidades</i>	8
2.4. SEGMENTO DE CLIENTES.....	9
2.4.1. <i>Descrición de los segmentos.</i>	9
2.4.2. <i>Rasgos principais.</i>	9
2.4.3. <i>Dimensión y cuantificación del mercado.</i>	9
2.4.4. <i>Diferenciación entre cliente y usuario.</i>	9
2.5. COMPETENCIA.	10
2.5.1. <i>Empresas competidoras.</i>	10
2.5.2. <i>Cota de mercado e posicionamento.</i>	10
2.5.3. <i>Análise comparativo.</i>	10
2.6. PROPOSTA DE VALOR.....	11
2.7. FORMA XURÍDICA.	11
2.8. PERMISOS E AUTORIZACIÓNS.....	12
2.9. INVESTIMENTOS.	12
2.10. CUSTOS.....	12
2.10.1. <i>Custos iniciais.</i>	12
2.10.2. <i>Custos fixos mensuais.</i>	12
2.10.3. <i>Custos variables (por cliente).</i>	13
2.10.4. <i>Impostos:</i>	13
2.11. INGRESOS.	13

2.11.1.	Política de prezos:	13
2.11.2.	Previsión de vendas (primeiro ano):.....	13
2.11.3.	Total ingresos estimados (primeiro ano):	13
2.12.	VIABILIDADE E ESCALABILIDADE	13
3.	ANÁLISE	13
3.1.	FUNCIONALIDADES DO SERVIZO.	13
3.2.	NECESIDADES TÉCNICAS.	14
3.2.1.	Software.....	14
3.2.2.	Hardware e infraestrutura	14
3.2.3.	Entorno de probas.....	15
3.2.4.	Servizos complementarios	15
4.	DESEÑO.	15
4.1.	CRONOGRAMA.....	15
4.2.	ESQUEMA DO MEU PROXECTO.....	16
4.2.1.	Elementos e a súa función no meu produto.....	16
4.3.	EXPLICACIÓN.	17
4.4.	RISCOS E PLAN DE PREVENCIÓN.	18
4.4.1.	Identificación de Riscos.	18
4.4.1.1.	Riscos Técnicos/Operacionais.	18
4.4.1.2.	Riscos de Servizo/Cliente.	19
4.4.1.3.	Riscos Lexislativos/Cumprimento.	19
4.4.2.	Plan de Prevención e Continuidade.....	19
4.4.2.1.	Copias de Seguridade (Backups):	19
4.4.2.2.	Recuperación ante Desastres (DR - Disaster Recovery):	20
4.4.2.3.	Supervisión, Control e Monitorización.....	20
4.4.2.4.	Soporte e Atención ao Cliente.	21
4.4.2.5.	Estatísticas de Uso e Rendemento.....	21
4.4.2.6.	Actualizacións e Xestión de Parches:	21
4.4.2.7.	Mellora Continua:	22
5.	PROTOTIPO.....	22
5.1.	WAZUH MANAGER.....	22
5.2.	WAZUH AGENT E SURICATA.....	22
5.2.1.	Configuración modo IDS.....	22
5.2.2.	Configuración modo IPS.....	24
5.3.	BOT TELEGRAM.....	25
5.4.	KALI LINUX CON NMAP.....	26
6.	PROPOSTAS DE MELLORA	30
6.1.	CREACIÓN DE REGLAS PERSONALIZADAS AVANZADAS (PARA AMEAZAS ESPECÍFICAS)	30
7.	CONCLUSIÓN.....	31
7.1.	PROBLEMAS NA EXECUCIÓN DO PROXECTO.	31
7.2.	REFLEXIÓN SOBRE O PROXECTO.	32
8.	BIBLIOGRAFÍA, REFERENCIAS E RECURSOS UTILIZADOS	32
9.	ANEXOS	32

1. Obxectivos e alcance do proxecto.

SecuLAN é unha empresa emerxente especializada na seguridade de redes locais para pequenas e medianas empresas. O presente proxecto céntrase na posta en marcha dunha empresa de ciberseguridade e no desenvolvemento dun prototipo funcional dun servizo IDS/IPS (Sistema de Detección e Prevención de Intrusións) para redes LAN, baseado na ferramenta Suricata.

1.1. Explicación de IDS/IPS.

IDS (Intrusion Detection System) ou Sistema de Detección de Intrusións: O IDS analiza o tráfico de rede en busca de actividades sospeitosas ou patróns que poidan indicar un ataque ou unha violación de seguridade. Se detecta algo raro, lanza unha alerta para que alguén tome medidas.

IPS (Intrusion Prevention System) ou Sistema de Prevención de Intrusións: Non só detecta as ameazas como o IDS, senón que tamén ten a capacidade de bloquear ou deter activamente esas actividades maliciosas. É como un gardacostas que non só ve o perigo, senón que tamén se interpón para protexerte.

1.1.1. Para que serve un IDS/IPS?

Ambos sistemas son cruciais para:

- Detectar ataques: Identificar intentos de acceso non autorizado, malware, explotación de vulnerabilidades e outros comportamentos maliciosos.
- Alertar sobre incidentes: Notificar aos administradores de seguridade cando se detecta unha posible ameaza.
- Proporcionar visibilidade: Ofrecer información detallada sobre o tráfico de rede e as posibles actividades de risco.
- (Só IPS) Bloquear e previr ataques: Deter activamente as ameazas antes de que poidan causar dano.
- Cumprir normativas: Axudar a cumprir con estándares e regulamentos de seguridade que requiren a monitorización e protección das redes.

1.1.2. A importancia da seguridade actualmente.

No mundo dixital actual, a seguridade é máis importante que nunca por varias razóns:

- Aumento das ciberameazas: Os ataques cibernéticos son cada vez máis sofisticados, frecuentes e danos.
- Dependencia da tecnoloxía: As empresas, os gobernos e os individuos dependen enormemente dos sistemas informáticos e das redes para case todas as actividades.
- Valor da información: A información persoal, financeira e empresarial ten un enorme valor, converténdose nun obxectivo principal para os cibercriminais.
- Impacto dos ataques: Unha brecha de seguridade pode ter consecuencias devastadoras, incluíndo perdas económicas, danos á reputación, interrupción de servizos e roubo de datos sensibles.
- Interconexión global: A natureza global de internet fai que as ameazas poidan orixinarse en calquera parte do mundo e propagarse rapidamente.

Neste contexto, ferramentas como os IDS/IPS son esenciais para protexer as infraestruturas dixitais, detectar e responder a incidentes de seguridade e minimizar os riscos asociados ás ciberameazas.

1.2. Explicación de Suricata.

A ferramenta Suricata é un sistema de detección de Intrusións (IDS) e tamén un Sistema de Prevención de Intrusións (IPS) de código aberto, gratuito e versátil. Esta ferramenta analiza o tráfico en rede en tempo real, que o compara cunhas regras xa predefinidas ou personalizadas, cando detecta patróns coincidentes coas regras xera alertas, no modo IPS ademais de avisar tamén as bloquea ou as descarta.

1.2.1. Características principais:

- Detección en tempo real: Analiza o tráfico de rede a medida que ocorre, permitindo a identificación e bloqueo inmediato de actividades maliciosas.
- Baseado en regras: Utiliza un conxunto de regras flexibles e personalizables para identificar patróns de tráfico sospeitosos. Estas regras poden ser creadas pola comunidade ou por usuarios individuais.
- Soporte para múltiples formatos: Entende e analiza unha ampla variedade de protocolos de rede e formatos de ficheiro.
- Integración con outras ferramentas: Pode integrarse con outras ferramentas de seguridade como SIEMs (Security Information and Event Management) para unha análise e resposta máis completa.
- Rendemento: Deseñado para un alto rendemento, capaz de manexar grandes volumes de tráfico de rede.

1.2.2. ¿Por que escoller Suricata e non outra ferramenta?

A elección de Suricata a miúdo baséase na súa natureza de código aberto, a súa flexibilidade e a súa activa comunidade. Isto significa que é gratuíto, altamente personalizable e beneficia das contribucións dunha ampla gama de expertos en seguridade. Ademais, o seu enfoque no rendemento faino unha boa opción para redes con moito tráfico.

1.2.3. Vantaxes:

- Código aberto e gratuíto: Non hai custos de licenza.
- Altamente flexible e personalizable: As regras pódense adaptar ás necesidades específicas.
- Forte comunidade: Amplia documentación e soporte dispoñible.
- Alto rendemento: Capaz de analizar grandes cantidades de datos.
- Múltiples capacidades: Funciona como IDS e IPS.

1.2.4. Inconvenientes:

- Curva de aprendizaxe: A configuración e xestión poden ser complexas para usuarios novatos.
- Mantemento de regras: Require unha actualización e axuste continuo das regras para manter a eficacia.
- Posibles falsos positivos: Unha configuración incorrecta das regras pode levar a alertas incorrectas.

1.3. Descrición do produto e servizo.

O servizo que ofrece SecuLAN consiste nunha solución integral de seguridade para redes locais que permite:

- Monitorización en tempo real do tráfico de rede.
- Detección de ameazas mediante análise de patróns de tráfico sospeitosos.
- Prevención activa mediante o bloqueo automatizado de intentos de intrusión.
- Informes detallados sobre actividades sospeitosas e intentos de ataque.
- Alertas personalizadas para distintos niveis de gravidade.
- Sistema de notificación inmediata mediante un bot de Telegram personalizado para cada cliente, que permite recibir alertas críticas de seguridade en tempo real en dispositivos móbiles.

1.4. Usuarios destinados.

Os usuarios potenciais deste servizo son:

- Pequenas e medianas empresas (PEMES) que non dispoñen dun departamento de IT especializado en ciberseguridade.
- Institucións educativas con redes complexas e múltiples usuarios.
- Despachos profesionais (avogados, xestorías, consultorías) que manexan datos sensibles.
- Provedores de servizos locais que necesiten protexer a súa infraestrutura.

1.5. Alcance do prototipo.

Neste prototipo incluíranse as seguintes funcionalidades:

- Instalación e configuración básica de Suricata nun entorno controlado.
- Implementación de regras de detección para os ataques máis comúns (escáneos de portos, ataques de forza bruta, malware coñecido).
- Configuración dun sistema de alertas en tempo real mediante Wazuh/Kibana.
- Mecanismos automatizados de resposta para bloquear tráfico malicioso.
- Xeración de informes básicos sobre actividade detectada.
- Desenrolo dun bot de Telegram básico para el envío automático de alertas de seguridade críticas a los responsables designados.

1.6. Motivación do proxecto.

A motivación principal para desenvolver este proxecto xorde da crecente necesidade de protección en redes corporativas de tamaño pequeno e mediano, un segmento frecuentemente desatendido polas grandes solucións comerciais de seguridade. Os incidentes de ciberseguridade afectan cada vez máis ás pequenas e medianas empresas, que non sempre contan cos recursos técnicos ou económicos para implementar solucións robustas. Segundo datos do INCIBE (Instituto Nacional de Ciberseguridade), as pequenas e medianas empresas galegas rexistraron un incremento do 47% en ataques dirixidos durante o último ano, sendo especialmente vulnerables aos ataques e roubo de datos. Este proxecto busca democratizar o acceso a ferramentas de seguridade avanzadas, adaptándoas ás necesidades e capacidades deste sector empresarial.

2. Estudo económico.

2.1. Idea de negocio.

O produto central de SecuLAN é un servizo de detección e prevención de intrusionés para redes LAN baseado en Suricata, unha ferramenta de código aberto de alto rendemento. O valor engadido reside na adaptación, configuración e mantemento personalizado para cada cliente, facendo accesible unha tecnoloxía complexa para empresas que carecen de persoal especializado en ciberseguridade.

2.1.1. Valor engadido e utilidade.

O proxecto SecuLAN se diferencia en el mercado pola súa proposta de valor única, que combina innovación tecnolóxica cun modelo de negocio adaptado especificamente ás necesidades do tecido empresarial galego:

2.1.1.1. Democratización de tecnoloxía avanzada

SecuLAN transforma ferramentas de ciberseguridade complexas e habitualmente inaccesibles para PYMES en solucións prácticas y asumibles:

- Tecnoloxía de nivel empresarial a custo accesible: Aproveitamos o potencial de Suricata, unha ferramenta IDS/IPS de código aberto e alto rendemento, adaptándoa especificamente ás necesidades e orzamentos de pequenas e medianas empresas galegas.
- Eliminación de barreiras técnicas: Simplificamos a implementación, configuración e mantemento de sistemas de seguridade avanzados que normalmente requirirían persoal especializado.

2.1.1.2. Sistema de notificacións móbiles vía Telegram

O noso elemento diferenciador máis distintivo é a integración dun sistema de alertas a través de Telegram, deseñado especificamente para cada cliente:

- Bot personalizado para cada empresa: Desenvolvemos un bot de Telegram único para cada cliente, adaptado á súa estrutura organizativa e necesidades específicas.

- Notificacións en tempo real: As alertas críticas de seguridade envíanse instantaneamente aos dispositivos móbiles dos responsables designados, permitindo respostas inmediatas incluso fóra do horario laboral.
- Diferentes niveis de alerta: Configuración personalizada de que eventos xeran notificacións segundo a súa gravidade e relevancia para cada negocio.
- Capacidade de resposta rápida: Posibilidade de executar comandos básicos de resposta directamente desde a interface de Telegram, reducindo significativamente o tempo de reacción ante incidentes.
- Informes periódicos automatizados: Xeración e envío de resumos de actividade coa periodicidade que o cliente prefira.

2.1.1.3. Modelo híbrido servizo – produto.

SecuLAN vai máis alá de ofrecer un simple produto software ou un servizo técnico illado:

- Solución integral: Combinamos tecnoloxía (sistema IDS/IPS baseado en Suricata) con servizos de valor engadido (configuración, formación, acompañamento).
- Acompañamento continuo: Ofrecemos non só a implementación inicial senón un servizo de mantemento e actualización constante que garante a eficacia do sistema.
- Adaptabilidade a necesidades cambiantes: Capacidade para evolucionar segundo as necesidades do cliente e as novas ameazas que van xurdindo.
- Formación incluída: Transferencia de coñecementos ao persoal do cliente para fomentar unha cultura de ciberseguridade dentro da organización.

2.1.1.4. Especialización local

O noso enfoque está especificamente deseñado para as PEMES galegas, considerando as súas particularidades:

- Coñecemento do tecido empresarial galego: Entendemos as características específicas dos sectores predominantes na nosa comunidade (servizos profesionais, comercio, industria manufactureira, hostalería e turismo).
- Servizo de proximidade: Ofrecemos atención presencial cando sexa necesario, con tempos de resposta rápidos grazas á nosa localización local.
- Adaptación á realidade dixital galega: Consideramos a infraestrutura dixital específica da rexión e as problemáticas particulares de conectividade en determinadas zonas.
- Aproveitamento de axudas rexionais: Coñecemento de programas como o Kit Dixital e outras axudas específicas da Xunta de Galicia para facilitar a implementación de solucións de ciberseguridade.

2.1.1.5 Soporte técnico especializado 24/7.

A implementación dun sistema IDS/IPS pode ser complexa e requirir coñecementos técnicos específicos para a súa configuración, mantemento e a correcta interpretación das alertas. Para garantir a máxima eficacia e tranquilidade aos nosos usuarios, ofrecerase un servizo de soporte técnico especializado dispoñible as 24 horas do día, os 7 días da semana.

Este soporte incluírá:

- Asesoramento e configuración inicial: Axuda na posta en marcha do sistema, configuración de regras personalizadas e axuste fino para optimizar a detección e prevención de ameazas segundo as necesidades específicas de cada contorna.
- Resolución de incidencias: Asistencia rápida e eficaz ante calquera problema técnico ou mal funcionamento do sistema, minimizando o tempo de inactividade e garantindo a continuidade da protección.
- Análise de alertas: Interpretación das alertas xeradas por Suricata e asesoramento sobre as mellores accións a tomar para mitigar as ameazas detectadas.
- Actualizacións e mantemento: Información e asistencia para o mantemento do sistema actualizado coas últimas definicións de ameazas e melloras de rendemento.

Esta combinación de elementos posiciona a SecuLAN como unha solución innovadora que ocupa un espazo único no mercado: profesional pero accesible, tecnoloxicamente avanzada pero próxima e personalizada, resolvendo así o dilema actual das PEMES galegas que se debaten entre solucións empresariais demasiado custosas ou alternativas básicas insuficientes para as súas necesidades reais de protección.

2.1.2. Produtos aumentados.

Como produtos aumentados, ofrecemos:

- Formación básica en ciberseguridade para o persoal da empresa cliente.
- Auditorías periódicas de seguridade.
- Asesoramento na implementación de políticas de seguridade.

2.2. Xustificación da idea.

A idea xorde para cubrir unha necesidade clara: segundo datos do IGE (Instituto Galego de Estatística), só o 23% das PEMES galegas contan con solucións de seguridade avanzadas, a pesar de que o 78% delas recoñecen a ciberseguridade como unha preocupación prioritaria.

O mercado actual presenta unha disxuntiva para as empresas de tamaño medio:

- Solucións empresariais complexas e custosas (como Cisco, Palo Alto ou Fortinet).
- Solucións básicas e xenéricas que non ofrecen unha protección adecuada.

SecuLAN posiciónase nun punto intermedio, ofrecendo unha solución profesional pero accesible, baseada en software de código aberto correctamente configurado e adaptado. Ademais, o Real Decreto-lei 12/2018 de seguridade das redes e sistemas de información obriga ás empresas a implementar medidas de seguridade adecuadas, o que incrementa a demanda deste tipo de servizos.

2.3. Análise DAFO

2.3.1. Debilidades

- Empresa de nova creación sen reputación establecida no mercado.
- Recursos limitados en comparación cos competidores máis grandes.
- Dependencia inicial de ferramentas de código aberto xa existentes.
- Capacidade limitada para xestionar moitos clientes simultaneamente na fase inicial.

2.3.2. Ameazas

- Competencia de grandes empresas de seguridade con solucións integrais.
- Posibles cambios na lexislación sobre protección de datos e ciberseguridade.
- Evolución rápida das ameazas que poidan superar a capacidade de actualización dos sistemas.
- Resistencia ao cambio por parte de empresas tradicionais.

2.3.3. Fortalezas

- Especialización en seguridade de redes LAN para PEMES.
- Solución baseada en software libre de alto rendemento (Suricata).
- Equipo técnico con formación específica en ciberseguridade.
- Modelo de servizo flexible e adaptable ás necesidades específicas de cada cliente.
- Prezos competitivos ao evitar licenzas comerciais custosas.
- Sistema de alertas instantáneas mediante Telegram que permite resposta inmediata.

2.3.4. Oportunidades

- Crecente concienciación sobre a importancia da ciberseguridade.
- Incremento dos ciberataques a PEMES na rexión.
- Novas normativas que obrigan a mellorar a seguridade informática.
- Posibilidade de colaboracións con asociacións empresariais locais.

- Programas de axudas para dixitalización e seguridade en PEMES (Kit Dixital).
- Alto uso de aplicacións de mensaxería como Telegram entre profesionais que facilita a adopción da nosa solución de notificacións.

2.4. Segmento de clientes.

2.4.1. Descripción de los segmentos.

O segmento principal de clientes está composto por pequenas e medianas empresas ubicadas na comunidade autónoma de Galicia, cun enfoque en sectores especialmente sensibles aos riscos dixitais, como:

- Servizos profesionais
- Industria lixeira e manufactura
- Comercio electrónico
- Saúde e clínicas privadas
- Turismo e hostalería.

Estas empresas a miúdo contan con infraestruturas dixitais básicas e intermedias, pero carecen de persoal especializado en ciberseguridade, o que fai vulnerables a ataques e erros humanos.

2.4.2. Rasgos principais.

- Tamaño: Entre 10 e 250 empregados.
- Dixitalización: En proceso ou parcialmente dixitalizadas, usando ferramentas como ERP, CRM, correo corporativo e servizos na nube.
- Presuposto limitado: Sensibles ao coste de servizos tecnolóxicos.
- Necesidade crítica: Teñen conciencia crecente sobre a ciberseguridade, especialmente por ataques recentes ou requirimentos legais (como el RGPD).
- Decisión centralizada: As decisións poden depender dos directores xerais ou responsables de TI, sen departamentos específicos de seguridade.

2.4.3. Dimensión y cuantificación del mercado.

En Galicia, segundo datos do IGE (Instituto Galego de Estatística) e o DIRCE, existen aproximadamente:

- Máis de 200.000 empresas rexistradas, das cales:
- Máis de 15.000 son pemes (10 a 249 empregados).
- Gran porcentaxe está en sectores industriais, comercio e servizos, todos con crecente dependencia dixital.

Estimase que o mercado potencial de ciberseguridade para pemes en Galicia ronda os 50-70 millóns de euros anuais, considerando:

- O crecemento medio do gasto en TI (5-8% anual).
- A presión reguladora (esquema nacional de seguridade, RGPD).

A necesidade de servizos como:

- Auditorías de seguridade.
- Protección do perímetro e endpoint.
- Backup y recuperación.
- Formación en ciberseguridade para empregados.

2.4.4. Diferenciación entre cliente y usuario.

- Cliente: A empresa (peme) que contrata os servizos. A decisión tomala o xerente, director de sistemas ou responsable de operacións.
- Usuario final: Empregados e persoal que usa os sistemas protexidos. Son os destinatarios das políticas, formación y ferramentas despregadas.

É clave entender esta diferenciación para deseñar solucións que sexan útiles para os usuarios, pero xustificables e atractivas para o cliente comprador.

2.5. Competencia.

2.5.1. Empresas competidoras

As principais empresas que operan neste mercado son:

- Innovatec Galicia

- **Servizos:** Ofrece solucións de ciberseguridade baseadas en tecnoloxía Fortinet, con paquetes adaptados a PEMES que inclúen antivirus, antispam, protección de correo electrónico, control de navegación, VPN e soporte 24/7.
- **Enfoque:** Combina medidas técnicas con formación ao persoal para minimizar riscos humanos.

- Evolk Galicia

- **Servizos:** Proporciona solucións integrais de ciberseguridade, incluíndo seguridade do perímetro, protección de datos, copias de seguridade, vixilancia continua e auditorías periódicas.
- **Enfoque:** Dirixido a PEMES que buscan protección completa e informes de seguimento regulares.

- Chip Work (A Coruña)

- **Servizos:** Ofrece solucións de ciberseguridade para empresas, incluíndo detección e resposta ante incidentes, protección de datos e recuperación ante desastres.
- **Enfoque:** Céntrase na capacidade de reacción rápida fronte a incidentes de seguridade.

- Plexus Tech

- **Servizos:** Participa en programas como Activa Ciberseguridade 4.0, ofrecendo medidas de seguridade dixital e transformación dixital para organizacións.
- **Enfoque:** Consultoría experta en ciberseguridade, colaborando con administracións públicas e empresas.

- Telefónica Tech (Vigo)

- **Servizos:** Centro de Talento e Tecnoloxía en Vigo, centrado no desenvolvemento de operacións e servizos de ciberseguridade para clientes globais.
- **Enfoque:** Ofrece servizos de ciberseguridade a gran escala, con presenza internacional.

2.5.2. Cota de mercado e posicionamento.

O mercado está moi fragmentado: non hai unha empresa dominante na ciberseguridade para pemes. As pemes aínda tenden a contratar servizos de TI xeralistas ou solo reactivos (post-ataque), o que deixa espazo para poñer unha empresa proactiva, especializada e de fiúza. Estimase que menos do 40% das pemes galegas teñen políticas ou solucións de ciberseguridade adecuadas, o que representa unha gran oportunidade.

2.5.3. Análise comparativo.

Empresa	Tipo de cliente	Prezo estimado	Personalización	Servizos principais	Puntos fortes / débiles fronte a SecuLAN
SecuLAN	PEMES galegas sen equipo de seguridade	2.500–6.500€ + 150–400€/mes	Alta (bot Telegram, regras IDS personalizadas)	IDS/IPS con Suricata, alertas en tempo real, formación, informes, mantemento continuo	Gran adaptación ao cliente e servizo local. Boa calidade-prezo.
Innovatec Galicia	PEMES dixitalizadas con máis recursos	5.000–12.000€ (segundo paquete)	Media	Solucións baseadas en Fortinet	Boa cobertura técnica pero dependente de

				(antivirus, firewall, VPN, antispam), soporte 24/7	software comercial. Prezo máis alto.
Evolk Galicia	PEMES e medianas empresas	4.000–10.000€ (segundo solución)	Media	Auditorías, vixilancia continua, backup, protección perimetral	Bo servizo integral, pero menos centrado na prevención activa vía IDS/IPS.
Chip Work	PEMES con infraestrutura TI	3.000–8.000€	Baixa-media	Recuperación ante desastres, resposta a incidentes, protección de datos	Enfoque reactivo máis que preventivo. Menor personalización.
Plexus Tech	Grandes empresas, administracións	10.000–30.000€	Baixa	Consultoría, seguridade 4.0, integración en transformación dixital	Fóra do alcance da maioría das PEMES. Solucións pouco adaptadas a pequenas.

2.6. Proposta de valor.

SecuLAN asegura as redes LAN contra ciberataques con solucións personalizadas e accesibles, protexendo os datos e a continuidade dos negocios en Galicia.

2.7. Forma xurídica.

A forma xurídica escollida para a nosa empresa será a de Sociedade Limitada (SL). Aínda que anteriormente existía a Sociedade Limitada Nova Empresa (SLNE), esta xa non ofrece vantaxes significativas con respecto á SL e prevese a súa progresiva desaparición. A SL é unha opción robusta e flexible para empresas de nova creación e peme, ofrecendo unha estrutura legal ben definida.

As principais características desta forma xurídica son:

- **Responsabilidade Limitada:** A responsabilidade dos socios fronte ás débedas da empresa está limitada ao capital social achegado. Isto significa que o patrimonio persoal dos socios non se ve afectado en caso de que a empresa contraia débedas.
- **Capital Social Mínimo:** Requírese un capital social mínimo de 1 euro, o que facilita a posta en marcha do negocio.
- **Número de Socios:** Pode ser constituída por un único socio (SLU) ou por varios socios.
- **Órganos de Xestión:** A xestión da empresa recae nos administradores, que poden ser socios ou non, e a toma de decisións importantes realízase mediante Xunta Xeral de Socios.
- **Tributación:** A Sociedade Limitada tributa a través do Imposto de Sociedades. Para as empresas de nova creación, existe unha bonificación no tipo impositivo, tributando ao 15% sobre os primeiros 300.000 € de base imponible durante os dous primeiros exercicios nos que se obteña base imponible positiva. Isto supón unha vantaxe fiscal considerable nos inicios da actividade empresarial.

A elección da Sociedade Limitada proporciona seguridade xurídica, facilita a separación do patrimonio persoal e empresarial, e ofrece un marco adecuado para o crecemento e desenvolvemento do proxecto.

Como empresa galega de nova creación no sector TIC e ciberseguridade, SecuLAN pode beneficiarse das seguintes axudas:

- Kit Dixital (Programa AceleraPYME)
- Programa INNOCÁMARAS (Cámara de Comercio)

- Axudas do IGAPE (Instituto Galego de Promoción Económica)
- Subvencións da Axencia para a Modernización Tecnolóxica de Galicia (AMTEGA).
- Bonificacións fiscais para empresas de nova creación.

2.8. Permisos e autorizacións

Para desenvolver a actividade necesitaranse:

- Certificación negativa do nome da empresa (CIRCE ou RMC).
- Obtención do certificado dixital para a empresa.
- Escritura pública de constitución ante notario.
- Depósito do capital social mínimo (3.012 €).
- Inscripción no Rexistro Mercantil Provincial.
- Alta na Axencia Tributaria (AEAT).
- Alta no Imposto de Actividades Económicas (IAE).
- Rexistro na Axencia Española de Protección de Datos (AEPD).
- Contratación de seguros obrigatorios.

2.9. Investimentos.

Concepto	Descrición	Custo estimado
Hardware	3 servidores de desenvolvemento e probas	9000€
	2 equipos portátiles de alta gama	4000€
	Equipo de rede (switches, routers, firewall físico)	3500€
Software	Licenzas de software de desenvolvemento e virtualización	2000€
	Certificados de seguridade	500€
	Desenvolvemento de bots de Telegram personalizados	1500€
Mobiliario	Mobiliario de oficina	3000€
Local	Aluguer inicial (6 meses) e fianza	6000€
	Acondicionamento do local	4000€
Marketing	Deseño web e materiais corporativos	2500€
	Campañas iniciais	3500€
Formación	Cursos e certificacións para o equipo	5000€
TOTAL		44500€

2.10. Custos.

2.10.1. Custos iniciais.

- Gastos de constitución da S.L: 1000€

2.10.2. Custos fixos mensuais.

- Aluguer de oficina: 1.000€/mes
- Suministros (electricidade, auga, internet): 350€/mes
- Salarios (2 técnicos e 1 comercial): 7.500€/mes
- Seguridade Social: 2.250€/mes
- Seguros: 200€/mes
- Servizos externos (xestión, limpeza): 400€/mes
- Custos financeiros: 150€/mes
- Mantemento de infraestrutura para bots de Telegram: 100€/mes
- Total custos fixos: 11.950€/mes

2.10.3. Custos variables (por cliente).

- Desprazamentos: 50-200€ (segundo localización)
- Hardware específico (se necesario): 300-1.500€
- Horas de configuración personalizada: 600-2.000€
- Formación personalizada: 300-900€
- Configuración e personalización do bot de Telegram: 150-300€
- Total custos variables por cliente: 1.400-4.900€

2.10.4. Impostos:

- Imposto de Sociedades: 15% (tipo reducido para empresas de nova creación).

2.11. Ingresos.

2.11.1. Política de prezos:

- Plan Básico: 2.500€ (instalación) + 150€/mes (mantemento). Inclúe bot de Telegram con alertas para eventos críticos.
- Plan Estándar: 4.000€ (instalación) + 250€/mes (mantemento). Inclúe bot de Telegram con alertas personalizables e informes semanais.
- Plan Premium: 6.500€ (instalación) + 400€/mes (mantemento). Inclúe bot de Telegram con alertas en tempo real, informes diarios e comandos de resposta rápida.

2.11.2. Previsión de vendas (primeiro ano):

- 1º trimestre: 3 clientes (1 básico, 2 estándar)
- 2º trimestre: 5 clientes (2 básicos, 2 estándar, 1 premium)
- 3º trimestre: 7 clientes (3 básicos, 3 estándar, 1 premium)
- 4º trimestre: 10 clientes (4 básicos, 4 estándar, 2 premium)

2.11.3. Total ingresos estimados (primeiro ano):

- Por instalacións: 87.500€
- Por mantemento mensual (acumulativo): 37.050€
- Total: 124.550€

2.12. Viabilidade e escalabilidade

O proxecto presenta viabilidade económica a partir do segundo trimestre, cando se espera alcanzar o punto de equilibrio. O retorno do investimento inicial estímase en 14 meses.

En canto á escalabilidade, o modelo de negocio permite:

- Incrementar o número de clientes sen un aumento proporcional nos custos fixos.
- Desenvolver módulos adicionais que poidan venderse como complementos.
- Ampliar a cobertura xeográfica a outras comunidades autónomas.
- Diversificar cara outros servizos relacionados (auditorías de seguridade, formación especializada).
- Expandir a plataforma de notificacións a outras aplicacións alén de Telegram.

A empresa será escalable ata aproximadamente 50 clientes co equipo inicial, momento no que sería necesario incorporar máis persoal técnico, o que permitiría continuar o crecemento de forma sostible.

3. Análise

3.1. Funcionalidades do servizo.

O sistema IDS/IPS desenvolvido por SecuLAN ofrece unha solución completa e adaptada ás necesidades das PEMES galegas, baseada na potente ferramenta de código aberto Suricata. Este sistema incorpora diferentes

funcionalidades que permiten tanto a detección como a prevención activa de ameazas na rede, todo elo complementado cun sistema de visualización moderno e alertas intelixentes para facilitar a xestión por parte dos clientes.

Un dos piares do servizo é a análise de tráfico en tempo real, que permite a inspección continua de todos os datos que circulan pola rede LAN da empresa. Este mecanismo supervisa automaticamente o tráfico e detecta patróns sospeitosos como escaneos de portos, intentos de acceso non autorizado ou comportamentos anómalos. Ademais, integra a análise de protocolos comúns para identificar posibles desviacións ou vulnerabilidades.

A maiores, o sistema está preparado para a detección de ameazas específicas, entre as que destacan os escaneos sistemáticos de servizos, os ataques por forza bruta (intentos reiterados de acceso a sistemas), os intentos de explotación de vulnerabilidades coñecidas e a presenza de tráfico asociado a malware ou redes de control maliciosas.

Pero SecuLAN non se limita a detectar; tamén actúa. Grazas á funcionalidade de prevención activa, o sistema pode bloquear automaticamente aquelas conexións que se identifiquen como perigosas, interrompendo a súa actividade en tempo real. Cada evento é rexistrado detalladamente para facilitar a súa análise posterior, e o cliente recibe alertas inmediatas ante calquera actividade potencialmente perigosa.

Para facilitar a supervisión e a toma de decisións, SecuLAN incorpora un panel de control centralizado baseado en Wazuh/Kibana. Esta interface gráfica permite visualizar o estado da rede, consultar informes detallados de incidentes e xestionar as regras de detección de forma flexible, adaptándoas ás características específicas de cada empresa.

Un dos elementos máis innovadores do servizo é o sistema de alertas móbiles mediante Telegram. Para cada cliente desenvólvese un bot exclusivo, configurado segundo a súa estrutura organizativa e as súas preferencias. Este bot envía notificacións críticas en tempo real directamente aos móbiles dos responsables da seguridade, e permite incluso executar comandos básicos de resposta dende a propia aplicación. Así mesmo, pódense configurar distintos niveis de alerta segundo a gravidade dos eventos, e programar o envío automatizado de informes periódicos.

En conxunto, estas funcionalidades converten a solución de SecuLAN nun servizo profesional, accesible e altamente eficaz para a protección de redes locais en pequenas e medianas empresas, combinando tecnoloxía avanzada cunha experiencia de uso intuitiva e adaptada ao contexto galego.

3.2. Necesidades técnicas.

Para implementar o servizo IDS/IPS proposto, SecuLAN require os seguintes recursos técnicos:

3.2.1. Software

- Suricata: Motor principal IDS/IPS para análise de tráfico en tempo real.
- Ubuntu: Sistema operativo base para a instalación de Suricata e demais compoñentes.
- Wazuh/Kibana: Ferramentas de visualización gráfica para monitorización e xestión de alertas.
- API de Telegram: Para o desenvolvemento e integración do bot de notificacións.

3.2.2. Hardware e infraestrutura

- Servidor dedicado: Equipo onde se instalará o sistema Suricata (especificacións segundo tamaño da rede).
- Equipo de simulación: Máquina con Kali Linux para realizar probas controladas de detección.
- Infraestrutura de virtualización: VirtualBox para simular entornos de rede con adaptadores en modo ponte.

- Servidor de bot: Infraestrutura para hospedar o servizo de bot de Telegram con alta dispoñibilidade.

3.2.3. Entorno de probas

- VirtualBox: Para crear a rede LAN virtualizada entre máquinas onde realizar as probas.
- Adaptadores en modo ponte: Configuración de rede que permite simular unha LAN completa entre máquinas virtuais.
- Kali Linux: Sistema operativo especializado en seguridade para realizar probas controladas.
- Nmap: Ferramenta para xerar tráfico de escaneo controlado e verificar a detección.

3.2.4. Servizos complementarios

- Actualización de sinaturas: Proceso periódico para manter a base de datos de ameazas actualizada.
 - Configuración personalizada: Adaptación das regras de detección segundo o perfil de cada cliente.
 - Monitorización continua: Supervisión do funcionamento correcto do sistema.
 - Mantemento de bots: Actualización e supervisión dos bots de Telegram implementados para cada cliente.
- Todos estes recursos técnicos foron contemplados na estimación económica presentada anteriormente, tanto nos custos fixos (para o desenvolvemento) como nos custos variables (para a implementación en cada cliente).

4. Deseño.

4.1. Cronograma.

TAREFAS	SEMANAS								
	Semana 1	Semana 2	Semana 3	Semana 4	Semana 5	Semana 6	Semana 7	Semana 8	Semana 9
Idea del proyecto									
Idea y propuesta del proyecto									
Planificación									
Preparación de máquinas virtuales									
Investigación de diferentes aplicaciones									
Configuración de máquinas virtuales									
Documentación									

Idea: Razoar e investigar varias opcións de proxecto e escoller unha para súa realización tendo en conta a súa dificultade, o tempo e súa factibilidade.

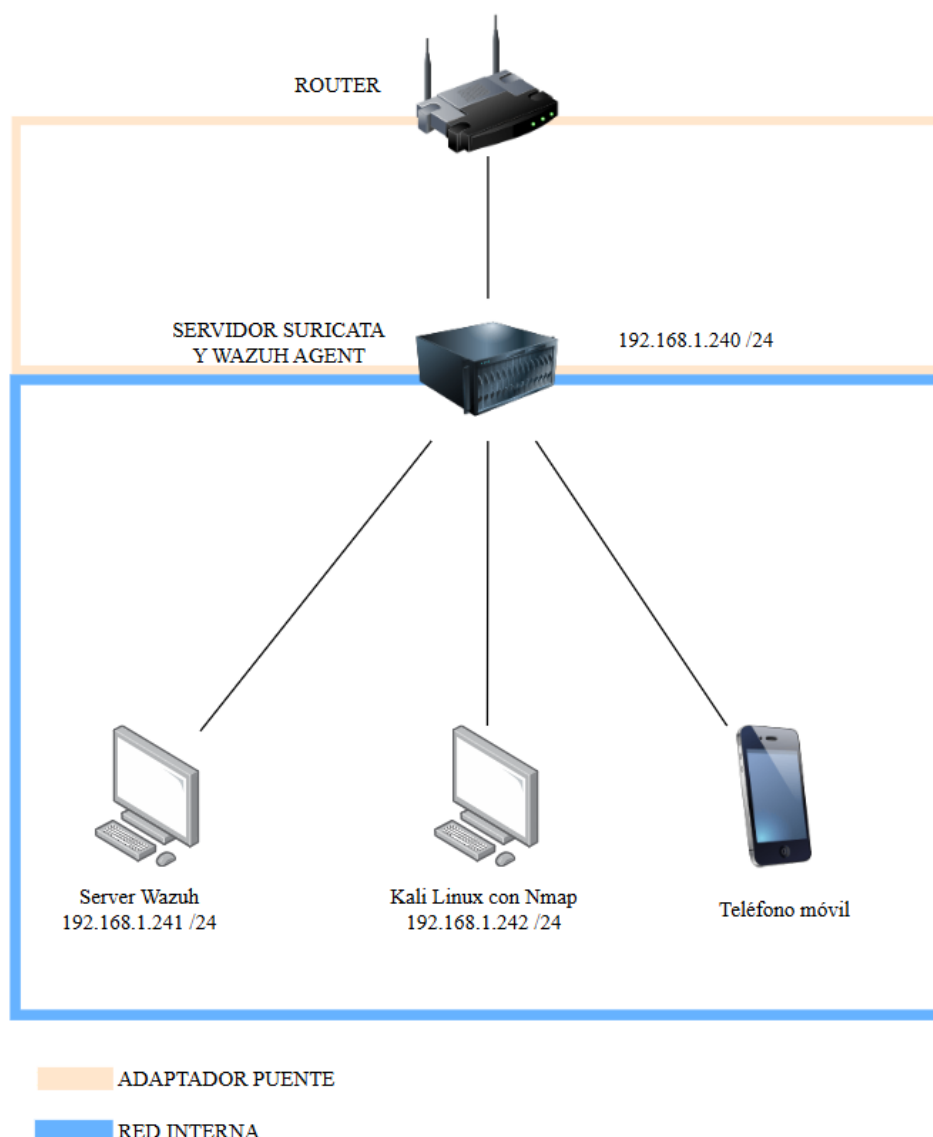
Proposta: Proposta do proxecto ao profesorado.

Investigación: Investigación sobre Suricata, Wazuh, Telegram e como realizar as configuracións necesarias.

Configuración en MV: Instalacións e configuracións realizadas nas 4 máquinas virtuais que se utilizan para o proxecto.

Documentación: Realización e documentación del proxecto en la memoria.

4.2. Esquema do meu proxecto.



4.2.1. Elementos e a súa función no meu produto.

Router do cliente PEME, a porta de entrada e saída principal da rede local do cliente a Internet. Todo o tráfico que entra ou sae da PEME pasa por aquí. No contexto de SecuLAN, este é o punto onde se configura o redireccionamento de tráfico ou mirroring para que Suricata poida inspeccionalo.

Servidor principal de seguridade, este é o hardware ou máquina virtual que aloxa os compoñentes clave da solución de SecuLAN. É o "cerebro" da seguridade.

Suricata (IDS/IPS), é o Sistema de Detección/Prevención de Intrusións de Rede (NIDS/NIPS). Monitoriza continuamente o tráfico de rede que flúe a través do Router (ou que se lle envía para análise). Utiliza un conxunto de regras (signatures) para identificar e alertar sobre actividades maliciosas (ataques, malware, intrusións). No modo IPS, pode bloquear activamente o tráfico sospeitoso.

Wazuh Manager, é o corazón do sistema Wazuh. Recibe e procesa os datos de seguridade de todos os axentes Wazuh despregados nos dispositivos do cliente, así como as alertas de Suricata. Realiza a correlación de eventos, a análise de ameazas, a avaliación de vulnerabilidades e xestiona a integridade dos ficheiros.

Wazuh Indexer, é a base de datos distribuída e o motor de busca utilizado por Wazuh para almacenar e indexar todos os datos e alertas de seguridade recibidos polo Wazuh Manager. Permite buscas rápidas e complexas sobre grandes volumes de datos históricos.

Wazuh Dashboard, é a interface de usuario gráfica (GUI) do sistema Wazuh. Permite aos administradores de SecuLAN (e potencialmente aos clientes) visualizar os datos de seguridade, crear paneis de control personalizados, explorar alertas, xestionar axentes e configurar regras e políticas.

Kali Linux, utilízase para simular ataques e actividades maliciosas (escaneos, explotacións, etc.) contra a rede de probas ou contra os sistemas de clientes en contornos controlados. Axuda a verificar a eficacia da detección e prevención de Suricata e Wazuh.

Nmap, ferramenta de descubrimento de rede e escaneo de vulnerabilidades. Emprégase para realizar escaneos de portos, identificación de servizos e sistemas operativos, simulando actividades de recoñecemento que un atacante podería realizar.

Bot de telegram, é a interface programática que SecuLAN creou en Telegram. Os scripts de integración de SecuLAN envían mensaxes a este bot.

Teléfono móbil, o dispositivo final que recibe as alertas en tempo real. Permite unha notificación inmediata e, no futuro, podería habilitar unha resposta rápida básica.

4.3. Explicación.

Router, é a porta de enlace principal da rede local da PEME a Internet. A súa función é enrutar o tráfico de datos entre os dispositivos internos do cliente e a rede externa (Internet). O servizo de SecuLAN configúrase para que Suricata poida inspeccionar este tráfico. Isto pode implicar configurar o router para reenviar o tráfico a través da máquina de Suricata.

Servidor principal de seguridade, é a plataforma hardware ou virtual que aloxa os programas e servizos centrais de SecuLAN (Suricata, Wazuh Manager, Wazuh Indexer, Wazuh Dashboard e os scripts de integración). Actúa como o centro de procesamento e xestión da seguridade para cada cliente. É o núcleo da solución tecnolóxica que SecuLAN implementa e xestiona para o cliente. A súa correcta configuración e mantemento son fundamentais para o funcionamento do servizo.

Suricata (IDS/IPS), é un sistema de detección e prevención de intrusións de rede (NIDS/NIPS). A súa función principal é analizar en tempo real o tráfico de rede que pasa polo servidor, comparándoo con regras predefinidas (signatures) para identificar patróns de ataque, vulnerabilidades coñecidas, actividades de malware, ou intentos de acceso non autorizado. É o motor de primeira liña que proporciona a capacidade de prevención activa e detección de intrusións a nivel de rede.

Wazuh Manager, é o cerebro do sistema Wazuh. A súa función principal é recibir, procesar e analizar os datos de seguridade que chegan de dúas fontes: as alertas de Suricata e os logs/eventos dos Axentes Wazuh instalados nos dispositivos do cliente. Tamén se encarga da correlación de eventos, a avaliación de vulnerabilidades e a xestión da integridade dos ficheiros. É o punto central de recollida e intelixencia. Sen o Manager, non sería posible consolidar a información de seguridade nin realizar a análise necesaria para xerar alertas significativas.

Wazuh Indexer, este compoñente é o almacén de datos distribuído e o motor de busca para todos os eventos e alertas de seguridade que procesa Wazuh. A súa función é indexar os datos de xeito eficiente para permitir buscas rápidas e complexas sobre grandes volumes de información histórica. Asegura que todos os datos

de seguridade estean dispoñibles para a análise forense, a xeración de informes e a consulta en tempo real, o que é esencial para o seguimento continuo da seguridade do cliente.

Wazuh Dashboard, é a interface de usuario gráfica (GUI) do sistema Wazuh. Permite aos operadores de SecuLAN visualizar os datos de seguridade de forma intuitiva, crear paneis de control personalizados (dashboards), explorar as alertas, xestionar os axentes instalados e configurar as regras e políticas de seguridade. É a ferramenta de xestión e visualización principal. Permite ao equipo de SecuLAN monitorar o estado da seguridade do cliente, responder a incidentes e demostrar o valor do servizo mediante informes visuais.

Kali Linux, é unha distribución de Linux especializada en probas de penetración e auditoría de seguridade (hacking ético). A súa función é simular ataques e actividades maliciosas para probar a robustez e a capacidade de detección do sistema de seguridade de SecuLAN. É unha ferramenta esencial para o desenvolvemento e validación do prototipo. Permite a SecuLAN asegurarse de que Suricata e Wazuh detectan e (no caso de IPS) bloquean eficazmente as ameazas antes de despregar a solución nun cliente real.

Nmap, é unha ferramenta de descubrimento de rede e auditoría de seguridade. A súa función é realizar escaneos de portos, identificar servizos en execución e recoñecer sistemas operativos nos equipos dunha rede. Utilízase especificamente no laboratorio de probas para simular as actividades de recoñecemento que un atacante faría. O obxectivo é verificar que Suricata é capaz de detectar estes escaneos como tráfico sospeitoso e xerar as alertas correspondentes.

Bot de Telegram, é un programa automatizado (un "bot") que reside na plataforma de Telegram. A súa función é recibir as mensaxes dos scripts de integración de SecuLAN e reenvialas aos usuarios de Telegram que se subscribiron a el. Serve como a canle de comunicación instantánea para as alertas de seguridade. É o intermediario tecnolóxico que conecta a súa solución de seguridade co teléfono do cliente.

Teléfono móbil, este é o dispositivo final que recibe as notificacións en tempo real das alertas de seguridade a través da aplicación de Telegram. Permite aos responsables designados da PEME ou ao equipo de SecuLAN estar informados sobre incidentes críticos de seguridade de forma inmediata, independentemente da súa localización. É un punto clave do seu valor engadido. Facilita a resposta rápida e a xestión remota de incidentes, diferenciando o seu servizo ao ofrecer unha solución de seguridade sempre accesible e reactiva.

4.4. Riscos e plan de prevención.

4.4.1. Identificación de Riscos.

4.4.1.1. Riscos Técnicos/Operacionais.

Fallos de Hardware:

- Fallo do servidor principal (disco duro, RAM, CPU).
- Fallo do router do cliente ou dos compoñentes de rede.
- Deterioro ou fallo dos equipos cliente onde residen os axentes Wazuh.

Fallos de Software/Configuración:

- Erro crítico en Suricata que impide o paso do tráfico (IPS en modo drop).
- Fallos no Wazuh Manager/Indexer/Dashboard que impiden a recollida/análise de datos.
- Erro nos scripts de integración con Telegram, impedindo as alertas.
- Configuración incorrecta de iptables ou Suricata, que bloquea tráfico lexítimo ou non detecta ameazas.
- Problemas de actualizacións que rompen a compatibilidade entre compoñentes (Suricata, Wazuh, SO).

Rendemento e Escalabilidade:

- Sobrecarga do servidor de Suricata/Wazuh debido a un alto volume de tráfico ou eventos.
- Wazuh Indexer (Elasticsearch/OpenSearch) enche o almacenamento.
- Suricata non pode procesar todo o tráfico (paquetes caídos/dropped packets).

Seguridade da Solución Propia:

- Vulnerabilidades no propio servidor de SecuLAN ou nos seus compoñentes (SO, Suricata, Wazuh).
- Acceso non autorizado ao Wazuh Dashboard ou ás credenciais de Telegram.
- Compromiso dos axentes Wazuh nos equipos cliente.
- Ataques de denegación de servizo (DoS) contra o servidor de SecuLAN.

Conectividade:

- Perda de conexión a Internet no cliente, impedindo a comunicación co servidor de SecuLAN (se está en nube) ou as actualizacións de regras.
- Interrupción da conexión coa API de Telegram.

4.4.1.2. Riscos de Servizo/Cliente.

Falsa Positivos/Negativos:

- Falsos Positivos: Suricata/Wazuh xeran demasiadas alertas sobre tráfico lexítimo, causando "fatiga de alertas" ou interrupcións innecesarias.
- Falsos Negativos: Non se detectan ameazas reais (Suricata non actualiza regras, ou as regras son ineficaces).

Confiabilidade da Notificación:

- O cliente non recibe as alertas críticas (problemas co teléfono, Telegram, etc.).
- O cliente ignora as alertas ou non sabe como actuar.

Recuperación:

- Tempo de inactividade prolongado en caso de fallo crítico do servidor, afectando a seguridade do cliente.
- Perda de datos históricos de seguridade debido a fallos sen copias de seguridade axeitadas.

Aceptación do Cliente:

- Resistencia á instalación de axentes nos equipos.
- Percepción de complexidade ou invasión de privacidade.

4.4.1.3 Riscos Lexislativos/Cumprimento.

Protección de Datos:

- Non cumprimento da normativa de protección de datos (RGPD en Galicia/UE) ao manexar datos de tráfico ou eventos de seguridade dos clientes.
- Almacenamento inseguro de información sensible.

Responsabilidade Legal:

- Perda de datos ou incidentes de seguridade no cliente que o servizo de SecuLAN non puido evitar, xerando reclamacións.

4.4.2. Plan de Prevención e Continuidade

Este plan detalla as estratexias para mitigar os riscos identificados.

4.4.2.1. Copias de Seguridade (Backups):

Deberíase facer una copia de seguridade de:

- Configuración do Servidor Principal: Ficheiros de configuración de Suricata (suricata.yaml, regras), Wazuh (ossec.conf, configuración de integracións, usuarios), iptables.

- Bases de Datos de Wazuh: Copias de seguridade do Wazuh Indexer (índices de Elasticsearch/OpenSearch) para preservar o historial de eventos e alertas.
- Imaxes de Máquinas Virtuais (se aplica): Se o servidor é unha VM, realizar snapshots ou copias completas da VM.

É recomendable almacenar os backups en:

- Almacenamento externo seguro e redundante (NAS dedicado, almacenamento en nube con cifrado).
- Preferentemente, copias fóra do sitio (off-site) para protección contra desastres físicos.

Cando deberíase facer os backups:

- Configuración: Diariamente, e inmediatamente despois de calquera cambio significativo.
- Bases de Datos: Diariamente (para un RPO de 24 horas) ou cada poucas horas para ambientes críticos.
- Imaxes VM: Semanalmente ou antes de grandes actualizacións.

Con que se faría:

- Ferramentas automatizadas (scripts cron, software de backup específico para Wazuh Indexer/Elasticsearch/OpenSearch).
- Probas regulares de restauración (polo menos trimestralmente) para asegurar a integridade e funcionalidade das copias.

4.4.2.2. Recuperación ante Desastres (DR - Disaster Recovery):

O noso obxectivo é minimizar o tempo de inactividade (RTO - Recovery Time Objective) e a perda de datos (RPO - Recovery Point Objective) en caso de fallo catastrófico.

As nos estratexias serían:

- Redundancia de Hardware: Se o servizo se aloxa on-premise no cliente, considerar servidores con redundancia de fontes de alimentación e RAID para os discos.
- Alta Dispoñibilidade (HA): Para contornos de maior escala, despregar Wazuh Manager e Indexer en clústeres de alta dispoñibilidade para evitar puntos únicos de fallo.
- Procedementos Documentados: Crear e manter guías detalladas para a restauración do sistema completo a partir das copias de seguridade, incluíndo a configuración de rede, servizos e base de datos.
- Entorno de Recuperación: Ter un plan para o despregamento rápido nun novo hardware ou VM en caso de fallo irrecuperable do servidor principal. Isto podería incluír imaxes de VM preconfiguradas.
- Probas de DR: Realizar exercicios de recuperación ante desastres polo menos anualmente para validar os procedementos e os tempos de recuperación.

4.4.2.3. Supervisión, Control e Monitorización.

Supervisión do Sistema SecuLAN:

- Monitorización de Recursos: CPU, RAM, uso de disco, ancho de banda no servidor de Suricata/Wazuh. Utilizar ferramentas como htop, Grafana con Prometheus (se se integran métricas), ou alertas do propio Wazuh sobre o seu rendemento.
- Monitorización de Servizos: Asegurar que Suricata, Wazuh Manager/Indexer/Dashboard e os scripts de Telegram estean sempre en execución. Utilizar ferramentas como systemd, monit, ou alertas de Wazuh sobre o estado dos seus propios compoñentes.
- Logs Internos: Revisar regularmente os logs de Suricata, Wazuh e do sistema operativo para detectar erros ou anomalías.

Control da Configuración:

- Control de Versións: Utilizar ferramentas como Git para xestionar os ficheiros de configuración de Suricata, Wazuh e os scripts de integración. Isto permite rastrexar cambios, reverter a versións anteriores e traballar en equipo.

- Procesos de Cambio: Establecer procedimientos formais para a modificación das configuracións, que inclúan revisións, probas nun ambiente de staging e aprobación antes de aplicar en produción.

Monitorización de Seguridade (a través de Wazuh):

- Paneis de Control (Dashboards): Personalizar os dashboards de Wazuh para mostrar as métricas de seguridade máis relevantes: top alertas, fontes de ataque, eventos por axente, tendencias.
- Regras de Alerta Personalizadas: Crear regras de Wazuh específicas para os clientes e o seu contexto, ademais das regras por defecto, para detectar ameazas máis avanzadas ou específicas do sector.
- Análise de Vulnerabilidades: Utilizar a capacidade de Wazuh para realizar escaneos de vulnerabilidades periódicos nos axentes.
- Monitorización da Integridade de Ficheiros (FIM): Configurar Wazuh para alertar sobre cambios non autorizados en ficheiros críticos do sistema ou da aplicación.

4.4.2.4. Soporte e Atención ao Cliente.

- Canles de Comunicación: Establecer canles claras para que os clientes poidan reportar problemas ou facer consultas (teléfono, correo electrónico, plataforma de soporte).
- Acordos de Nivel de Servizo (SLA): Definir os tempos de resposta e resolución para diferentes tipos de incidentes, incluíndo as alertas de seguridade.
- Formación ao Cliente: Ofrecer formación básica aos responsables do cliente sobre como interpretar as alertas de Telegram e cales son os pasos iniciais a seguir.
- Equipo de Soporte: Ter un equipo (aínda que sexa pequeno inicialmente) dispoñible para responder ás alertas críticas 24/7 (se o servizo o require) e resolver problemas técnicos.

4.4.2.5. Estatísticas de Uso e Rendemento.

- Métricas de Servizo: Recopilar datos sobre o número de alertas xeradas, o volume de tráfico analizado por Suricata, o número de eventos procesados por Wazuh, o tempo medio de resposta a alertas.
- Feedback do Cliente: Recopilar feedback regular dos clientes sobre a utilidade das alertas e a satisfacción co servizo.
- Análise de Tendencias: Utilizar as estatísticas para identificar patróns, optimizar a configuración, prever necesidades de escalabilidade e demostrar o valor do servizo.
- Informes Periódicos: Xerar informes automáticos ou manuais (semanais/mensuais) para os clientes, resumindo a actividade de seguridade e o rendemento do servizo.

4.4.2.6. Actualizacións e Xestión de Parches:

Sistema Operativo: Manter o sistema operativo do servidor principal actualizado con parches de seguridade regulares.

Suricata:

- Regras (Signatures): Automatizar a actualización diaria ou horaria das regras de Suricata (por exemplo, de Emerging Threats Open ou Proofpoint ET Pro para mellor calidade).
- Versións: Planificar a actualización a novas versións estables de Suricata para beneficiarse de melloras de rendemento e novas capacidades de detección.

Wazuh:

- Axentes: Asegurar que os axentes Wazuh nos clientes se actualizan á par co Wazuh Manager.
- Componentes do Servidor: Manter o Wazuh Manager, Indexer e Dashboard actualizados coas últimas versións estables.

Scripts de Integración: Manter os scripts de Telegram actualizados, especialmente se a API de Telegram cambia.

Procesos de Actualización: Implementar un proceso de actualización escalonado (desenvolvemento/test -> staging -> produción) para minimizar o risco de interrupcións.

4.4.2.7. Mellora Continua:

- Revisión Post-Incidente: Cada vez que ocorra un incidente real (detectado ou non), realizar unha análise post-mortem para identificar as causas raíz e mellorar as regras de detección, os procedementos de resposta ou a configuración.
- Análise de Falsos Positivos: Axustar as regras de Suricata e Wazuh para reducir os falsos positivos e mellorar a precisión das alertas.
- Novas Ameazas: Estar ao día das últimas ameazas e tendencias de ciberseguridade para adaptar as regras e as capacidades de detección do servizo.
- Expansión do Servizo: Considerar a integración con outras ferramentas de seguridade ou a ampliación das funcionalidades de Wazuh (e.g., resposta activa dende axentes).
- Este plan integral axudará a SecuLAN non só a implementar unha solución tecnolóxica, senón tamén a ofrecer un servizo de seguridade fiable, proactivo e de alta calidade ás PEMES galegas.

5. Prototipo

5.1. Wazuh Manager.

Para Wazuh server necesitaremos 3 programas en concreto, o Indexer, o Manager e o Dashboard, que os descargaremos mediante o proceso curl executaremos o script de instalación con -a, que é o all-in-one. A continuación entraremos na configuración do ossec e cambiaremos o tipo de formato de logins de plain a json.

```
<!-- Choose between "plain", "json", or "plain,json" for the format of internal logs -->  
<logging>  
  <log_format>json</log_format>  
</logging>
```

5.2. Wazuh Agent e Suricata.

O axente Wazuh execútase no host que queres monitorizar e comunícase co servidor Wazuh, enviando datos case en tempo real a través dunha canle cifrada e autenticada. Así que para cifrar esa canle teremos que engadir o repositorio oficial de Wazuh, que inclúe a clave GPG.

Ao descargar o repositorio, instalamos o servizo Wazuh-agent e logo modificaremos o arquivo ossec e lle modificaremos WAZUH_MANAGER="XXXX" no que poñeremos a IP do noso servidor Wazuh, que é a "192.168.1.241". Activamos e reiniciamos o servizo do axente Wazuh, e revisamos o seu status.

Wazuh intégrase cun sistema de detección de intrusións baseado en rede (NIDS) para mellorar a detección de ameazas mediante a monitorización e a análise do tráfico de rede, así que a continuación, ensinarei como implementar Suricata, así que, o noso primeiro paso que se tivo que facer foi engadir os repositorios de Suricata, actualizar o ordenador e despois instalar o servizo Suricata. E a continuación, descargar, extraer e darlle permisos ao conxunto de regras que che da Suricata.

5.2.1. Configuración modo IDS.

No ficheiro de configuración de Suricata, que é `/etc/suricata/suricata.yaml`, e cambiar a IP de HOME_NET que sería a IP do axente Wazuh e do Suricata, e que EXTERNAL_NET sexa distinta á HOME_NET.

```
vars:
  # more specific is better for alert accuracy and performance
  address-groups:
    HOME_NET: "192.168.1.240"
    #HOME_NET: "[192.168.0.0/16]"
    #HOME_NET: "[10.0.0.0/8]"
    #HOME_NET: "[172.16.0.0/12]"
    #HOME_NET: "any"

    EXTERNAL_NET: "!$HOME_NET"
    #EXTERNAL_NET: "any"
```

Ademais, teremos que especificar as regras que imos utilizar no noso servizo no apartado de **default-rule-path**, por defecto é /var/lib/suricata/rules, pero nós imolo a cambiar por /etc/suricata/rules e os ficheiros de regras vamos a escoller todos os que descargamos anteriormente:

```
default-rule-path: /etc/suricata/rules

rule-files:
- "*.rules"
```

Tamén temos que comprobar que temos os stats habilitados.

```
# Global Stats configuration
stats:
  enabled: yes
  # The interval field (in seconds) controls the interval at
  # which stats are updated in the log.
```

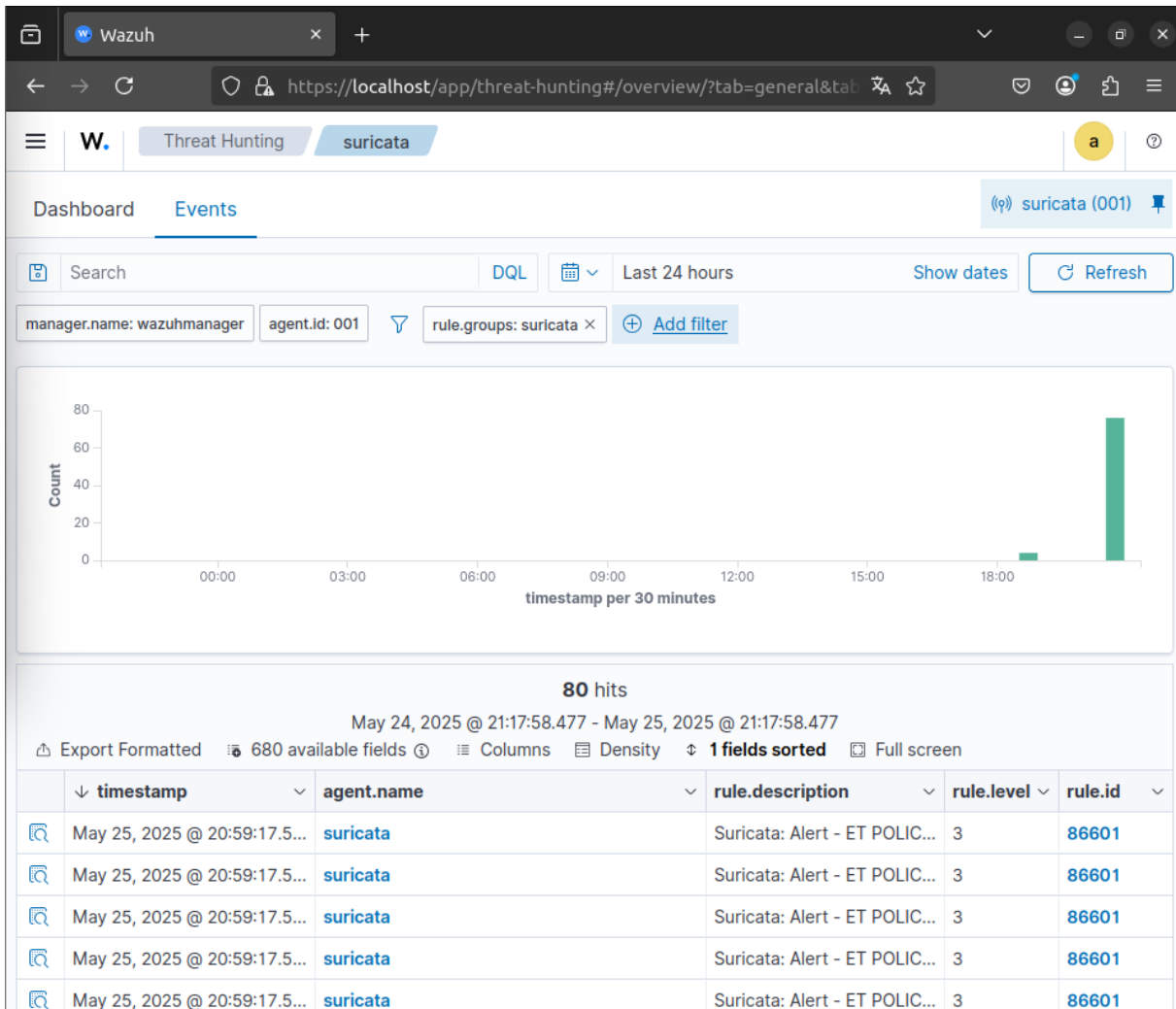
É por ultimo, teremos que modificar o nome da interface pola que estamos conectados, no meu caso é a "enp0s3", e é recomendable cambiar tamén o cluster-id, porque moitas veces o que che da suricata por defecto, pode dar algún erro de Linux kernel.

```
af-packet:
- interface: enp0s3
  # Number of receive threads. "auto" uses the number of cores
  #threads: auto
  # Default clusterid. AF_PACKET will load balance packets based on flow.
  cluster-id: 98
  # Default AF_PACKET cluster type. AF_PACKET can load balance per flow or per hash.
  # This is only supported for Linux kernel > 3.1
```

Reiniciamos o servizo e a continuación, engadiremos no arquivo ossec a seguinte configuración que permite que o axente Wazuh lea o ficheiro de rexistros de Suricata.

```
<localfile>
  <log_format>json</log_format>
  <location>/var/log/suricata/eve.json</location>
</localfile>
```

E reiniciamos a maquina, para logo entrar no dashboard do Wazuh Server, engadir o axente para poder ver os seus avisos e filtralos por rule.groups:suricata do noso axente.



Unha vez configurado todo, temos que probar se o ficheiro está ben configurado, con **suricata -T** e logo con **sudo suricata -c /etc/suricata/suricata.yaml -i enp0s3** vemos se funciona correctamente.

```
usuario@servidor:~$ sudo suricata -c /etc/suricata/suricata.yaml -i enp0s3
i: suricata: This is Suricata version 7.0.10 RELEASE running in SYSTEM mode
W: af-packet: enp0s3: AF_PACKET tpacket-v3 is recommended for non-inline operation
i: threads: Threads created -> W: 4 FM: 1 FR: 1 Engine started.
```

5.2.2. Configuración modo IPS.

O primeiro que faremos é editar o arquivo `/etc/hosts` e engadir a dirección IP de localhost co nome da nosa máquina para evitar erros na solución de nomes posteriormente.

```
GNU nano 6.2 /etc/hosts
127.0.0.1 localhost
127.0.1.1 usuario-VirtualBox
127.0.0.1 servidor
```

Despois verificamos se o noso suricata é compatible con NFQUEUE de iptables co comando **suricata --build-info | grep NFQ**, se é compatible entón teremos que modificar o arquivo de **suricata.yaml** e descomentar o apartado de **nfq** e habilitar o modo **accept**, este modo fai que suricata emite un veredicto final (pasar ou descartar) e logo ese paquete non será inspeccionado.


```
nfq:
mode: accept
# repeat-mark: 1
# repeat-mask: 1
# bypass-mark: 1
# bypass-mask: 1
# route-queue: 2
# batchcount: 20
# fail-open: yes
```

Logo se terá que facer cambios no arquivo `/etc/default/suricata`, que é o arquivo de inicio para Suricata que nos di que o vai a escoitar, pasaremos de ter `"LISTENMODE=af-packet"` a `"LISTENMODE=nfqueue"`.

```
# Listen mode: pcap, nfqueue, custom_nfqueue or af-packet
# depending on this value, only one of the two following options
# will be used (af-packet uses neither).
# Please note that IPS mode is only available when using nfqueue
#LISTENMODE=af-packet
LISTENMODE=nfqueue
```

E agora temos que configurar as regras de trafico de rede a Suricata, a nosa maquina vai ser un intermediario entre o router e os equipos da rede, asi que teremos que aplicar a seguinte regra: **sudo iptables -I FORWARD -j NFQUEUE --queue-num 0**.

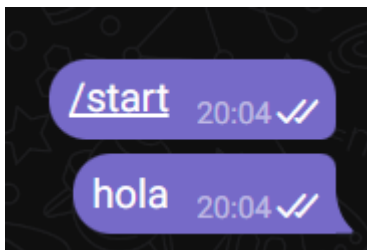
Ao habilitar o nfqueue, teremos que cambiar nas regras a palabra "alert" to "drop", para que detecte na interface que paquetes ten que bloquear.

5.3. Bot Telegram.

O primeiro que teremos que facer é entrar en Telegram e buscar BotFather, escribir `/newbot` e darlle un apodo ao noso bot e un nome de usuario. Cando o creas, BotFather proporciona un token:

```
Use this token to access the HTTP API:
7986266593:AAE2keoGXGEo0nSe08syG7sfmAQF-pckPMw
Keep your token secure and store it safely, it can be used by
anyone to control your bot.
```

A posteriori, tes que mandarlle un mensaxe de `/start` e un para poder recoller o seu id para poder conectarnos a el máis tarde.



A continuación, entraremos en:

<https://api.telegram.org/bot7986266593:AAE2keoGXGEo0nSe08syG7sfmAQF-pckPMw/getUpdates>

Onde conseguiremos o id do noso chat co bot que creamos antes.

```
{
  "ok": true,
  "result": [
    {
      "update_id": 838574668,
      "message": {
        "message_id": 1,
        "from": {
          "id": 5757686894,
          "is_bot": false,
          "first_name": "pau",

```

Logo iremos a seguinte dirección:

<https://github.com/OpenSecureCo/Demos/blob/main/Telegram%20Integration>

E descargaremos os arquivos bash e py na maquina que contén o Wazuh Manager, e no arquivo python modificaremos a liña 8 na que se encontra o apartado de CHAT_ID e lle poñemos o id da anterior captura.

```
GNU nano 6.2 /var/ossec/integrations/custom-telegram.py
#!/usr/bin/env python

import sys
import json
import requests
from requests.auth import HTTPBasicAuth

#CHAT_ID="xxxx"
CHAT_ID="5757686894"
```

Cambiarémoslles os permisos ambos arquivos descargados e o usuario e grupo ao que pertencen.

```
chown root:wazuh /var/ossec/integrations/custom-telegram*
chmod 750 /var/ossec/integrations/custom-telegram*
```

E engadiremos no arquivo ossec a integración do noso bot de telegram.

```
<integration>
  <name>custom-telegram</name>
  <level>3</level>
  <hook_url>https://api.telegram.org/bot7986266593:AAE2keoGXGEo0nSe08syG7sfmAQF-pckPMw/sendMessage</hook_url>
  <alert_format>json</alert_format>
  <group>syscheck,authentication_failed,_telegram_alerts,authentication_success,account_changed,suricata</group>
</integration>
```

E por último, reiniciamos o noso Manager, e ao rato deberían aparecer nos nosos bot.

```
← IA Ids/lps alert bot
{"alert_level": "3", "agent": "suricata"} 21:00
{"description": "Suricata: Alert - ET POLICY GNU/Linux APT User-Agent Outbound likely related to package management", "alert_level": "3", "agent": "suricata"} 21:00
{"description": "Suricata: Alert - ET POLICY GNU/Linux APT User-Agent Outbound likely related to package management", "alert_level": "3", "agent": "suricata"} 21:00
```

5.4. Kali Linux con Nmap.

Na máquina que contén Nmap, faremos varias probas para ver se suricata funciona correctamente e poder ver en que ten erros e xa de paso ver que pode detectar o noso bot e que non.

1. Escaneo de Ping (ICMP Echo Request):

sudo nmap -PE 192.168.1.240

```
(kali㉿kali)-[~]  
$ sudo nmap -PE 192.168.1.240  
[sudo] password for kali:  
Starting Nmap 7.95 ( https://nmap.org ) at 2025-06-02 18:28 CEST  
Nmap scan report for 192.168.1.240  
Host is up (0.0028s latency).  
All 1000 scanned ports on 192.168.1.240 are in ignored states.  
Not shown: 1000 closed tcp ports (reset)  
MAC Address: 08:00:27:C7:32:ED (PCS Systemtechnik/Oracle VirtualBox virtual NIC)  
  
Nmap done: 1 IP address (1 host up) scanned in 0.37 seconds
```

2. Escaneo de Puertos TCP Básico (SYN Scan - Stealth Scan):

sudo nmap -sS 192.168.1.240

```
(kali㉿kali)-[~]  
$ sudo nmap -sS 192.168.1.240  
Starting Nmap 7.95 ( https://nmap.org ) at 2025-06-02 18:29 CEST  
Nmap scan report for 192.168.1.240  
Host is up (0.00087s latency).  
All 1000 scanned ports on 192.168.1.240 are in ignored states.  
Not shown: 1000 closed tcp ports (reset)  
MAC Address: 08:00:27:C7:32:ED (PCS Systemtechnik/Oracle VirtualBox virtual NIC)  
  
Nmap done: 1 IP address (1 host up) scanned in 0.49 seconds
```

3. Escaneo de Puertos TCP Completo (Connect Scan):

sudo nmap -sT 192.168.1.240

```
(kali㉿kali)-[~]  
$ sudo nmap -sT 192.168.1.240  
Starting Nmap 7.95 ( https://nmap.org ) at 2025-06-02 18:29 CEST  
Nmap scan report for 192.168.1.240  
Host is up (0.0030s latency).  
All 1000 scanned ports on 192.168.1.240 are in ignored states.  
Not shown: 1000 closed tcp ports (conn-refused)  
MAC Address: 08:00:27:C7:32:ED (PCS Systemtechnik/Oracle VirtualBox virtual NIC)  
  
Nmap done: 1 IP address (1 host up) scanned in 0.47 seconds
```

4. Escaneo de Puertos UDP:

sudo nmap -sU -p 161,53,137 192.168.1.240

```
(kali㉿kali)-[~]  
$ sudo nmap -sU -p 161,53,137 192.168.1.240  
Starting Nmap 7.95 ( https://nmap.org ) at 2025-06-02 18:31 CEST  
Nmap scan report for 192.168.1.240  
Host is up (0.00094s latency).  
  
PORT      STATE SERVICE  
53/udp    closed domain  
137/udp   closed netbios-ns  
161/udp   closed snmp  
MAC Address: 08:00:27:C7:32:ED (PCS Systemtechnik/Oracle VirtualBox virtual NIC)  
  
Nmap done: 1 IP address (1 host up) scanned in 0.27 seconds
```

5. Escaneo de Versións de Servizos:

sudo nmap -sV 192.168.1.240

```
(kali@kali)-[~]
$ sudo nmap -sV 192.168.1.240
Starting Nmap 7.95 ( https://nmap.org ) at 2025-06-02 18:33 CEST
Nmap scan report for 192.168.1.240
Host is up (0.00066s latency).
All 1000 scanned ports on 192.168.1.240 are in ignored states.
Not shown: 1000 closed tcp ports (reset)
MAC Address: 08:00:27:C7:32:ED (PCS Systemtechnik/Oracle VirtualBox virtual NIC)

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 0.71 seconds
```

6. Detección de Sistema Operativo:

sudo nmap -O 192.168.1.240

```
(kali@kali)-[~]
$ sudo nmap -O 192.168.1.240
Starting Nmap 7.95 ( https://nmap.org ) at 2025-06-02 18:35 CEST
Nmap scan report for 192.168.1.240
Host is up (0.0013s latency).
All 1000 scanned ports on 192.168.1.240 are in ignored states.
Not shown: 1000 closed tcp ports (reset)
MAC Address: 08:00:27:C7:32:ED (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
Too many fingerprints match this host to give specific OS details
Network Distance: 1 hop

OS detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 1.80 seconds
```

7. Escaneo Agresivo:

sudo nmap -A 192.168.1.240

```
(kali@kali)-[~]
$ sudo nmap -A 192.168.1.240
Starting Nmap 7.95 ( https://nmap.org ) at 2025-06-02 18:37 CEST
Nmap scan report for 192.168.1.240
Host is up (0.0013s latency).
All 1000 scanned ports on 192.168.1.240 are in ignored states.
Not shown: 1000 closed tcp ports (reset)
MAC Address: 08:00:27:C7:32:ED (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
Too many fingerprints match this host to give specific OS details
Network Distance: 1 hop

TRACEROUTE
HOP RTT ADDRESS
1 1.32 ms 192.168.1.240

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 2.23 seconds
```

8. Escaneo de Puertos Específicos o Rango de Puertos:

sudo nmap -p 1-1000 192.168.1.240

```
(kali@kali)-[~]
$ sudo nmap -p 1-1000 192.168.1.240
Starting Nmap 7.95 ( https://nmap.org ) at 2025-06-02 18:38 CEST
Nmap scan report for 192.168.1.240
Host is up (0.0049s latency).
All 1000 scanned ports on 192.168.1.240 are in ignored states.
Not shown: 1000 closed tcp ports (reset)
MAC Address: 08:00:27:C7:32:ED (PCS Systemtechnik/Oracle VirtualBox virtual NIC)

Nmap done: 1 IP address (1 host up) scanned in 0.30 seconds
```


sudo nmap -p 21,22,23,80,443,3389 192.168.1.240

```
(kali㉿kali)-[~]  
$ sudo nmap -p 21,22,23,80,443,3389 192.168.1.240  
Starting Nmap 7.95 ( https://nmap.org ) at 2025-06-02 18:39 CEST  
Nmap scan report for 192.168.1.240  
Host is up (0.00091s latency).  
  
PORT      STATE SERVICE  
21/tcp    closed ftp  
22/tcp    closed ssh  
23/tcp    closed telnet  
80/tcp    closed http  
443/tcp   closed https  
3389/tcp  closed ms-wbt-server  
MAC Address: 08:00:27:C7:32:ED (PCS Systemtechnik/Oracle VirtualBox virtual NIC)  
  
Nmap done: 1 IP address (1 host up) scanned in 0.16 seconds
```

9. Escaneos "Sixilosos":

sudo nmap -sX 192.168.1.240

```
(kali㉿kali)-[~]  
$ sudo nmap -sX 192.168.1.240  
Starting Nmap 7.95 ( https://nmap.org ) at 2025-06-02 18:43 CEST  
Nmap scan report for 192.168.1.240  
Host is up (0.0032s latency).  
All 1000 scanned ports on 192.168.1.240 are in ignored states.  
Not shown: 1000 closed tcp ports (reset)  
MAC Address: 08:00:27:C7:32:ED (PCS Systemtechnik/Oracle VirtualBox virtual NIC)  
  
Nmap done: 1 IP address (1 host up) scanned in 0.33 seconds
```

sudo nmap -sN 192.168.1.240

```
(kali㉿kali)-[~]  
$ sudo nmap -sN 192.168.1.240  
Starting Nmap 7.95 ( https://nmap.org ) at 2025-06-02 18:43 CEST  
Nmap scan report for 192.168.1.240  
Host is up (0.0080s latency).  
All 1000 scanned ports on 192.168.1.240 are in ignored states.  
Not shown: 1000 closed tcp ports (reset)  
MAC Address: 08:00:27:C7:32:ED (PCS Systemtechnik/Oracle VirtualBox virtual NIC)  
  
Nmap done: 1 IP address (1 host up) scanned in 0.39 seconds
```

sudo nmap -sF 192.168.1.240

```
(kali㉿kali)-[~]  
$ sudo nmap -sF 192.168.1.240  
Starting Nmap 7.95 ( https://nmap.org ) at 2025-06-02 18:43 CEST  
Nmap scan report for 192.168.1.240  
Host is up (0.0019s latency).  
All 1000 scanned ports on 192.168.1.240 are in ignored states.  
Not shown: 1000 closed tcp ports (reset)  
MAC Address: 08:00:27:C7:32:ED (PCS Systemtechnik/Oracle VirtualBox virtual NIC)  
  
Nmap done: 1 IP address (1 host up) scanned in 0.47 seconds
```

10. Escaneo con Fragmentación de Paquetes:

sudo nmap -f 192.168.1.240

```
(kali㉿kali)-[~]  
$ sudo nmap -f 192.168.1.240  
Starting Nmap 7.95 ( https://nmap.org ) at 2025-06-02 18:45 CEST  
Nmap scan report for 192.168.1.240  
Host is up (0.0024s latency).  
All 1000 scanned ports on 192.168.1.240 are in ignored states.  
Not shown: 1000 closed tcp ports (reset)  
MAC Address: 08:00:27:C7:32:ED (PCS Systemtechnik/Oracle VirtualBox virtual NIC)  
  
Nmap done: 1 IP address (1 host up) scanned in 0.88 seconds
```

11. Escaneo con Scripts NSE:

`sudo nmap -sS --script=vuln 192.168.1.240`

```
(kali㉿kali)-[~]  
$ sudo nmap -sS --script=vuln 192.168.1.240  
[sudo] password for kali:  
Starting Nmap 7.95 ( https://nmap.org ) at 2025-06-02 18:56 CEST  
Pre-scan script results:  
| broadcast-avahi-dos:  
|   Discovered hosts:  
|     224.0.0.251  
|   After NULL UDP avahi packet DoS (CVE-2011-1002).  
|_  Hosts are all up (not vulnerable).  
Nmap scan report for 192.168.1.240  
Host is up (0.0050s latency).  
All 1000 scanned ports on 192.168.1.240 are in ignored states.  
Not shown: 1000 closed tcp ports (reset)  
MAC Address: 08:00:27:C7:32:ED (PCS Systemtechnik/Oracle VirtualBox virtual NIC)  
  
Nmap done: 1 IP address (1 host up) scanned in 35.35 seconds
```

Demostración das alertas recibidas por Suricata ao recibir os diferentes escaneos:

<https://youtube.com/shorts/tg00CEda7qI?si=j GpkQcieAmp7KpN>

6. Propostas de mellora

6.1. Creación de regras personalizadas avanzadas (para ameazas específicas).

Ir máis aló das regras predefinidas e desenvolver regras personalizadas para detectar patróns de ataque moi específicos ou ameazas dirixidas a servizos concretos do cliente final. Aínda que se mencionan as regras, o tempo limitou a creación dun conxunto extenso e complexo de regras totalmente personalizadas para escenarios de ataque moi nicho. O foco foi a configuración básica e demostración.

Como se levaría a cabo:

- **Análise de Ameazas:** Identificar as ameazas máis comúns ou específicas para o tipo de empresas ás que se dirixe o servizo.
- **Estudo de Protocolos:** Profundar no coñecemento de protocolos de rede e aplicación para identificar patróns anómalos.
- **Desenvolvemento e Probas:** Escribir as regras Suricata (sid, rev, msg, flow, content, pcre, etc.) e probalas rigorosamente nun ambiente controlado para evitar falsos positivos e asegurar a súa eficacia.
- **Valor Engadido:** Proporcionaría unha capa de seguridade altamente especializada e adaptada, aumentando a precisión na detección e reducindo o ruído das alertas xerais, o que é moi valioso para clientes con infraestruturas ou aplicacións particulares.

7. Conclusións

O punto de partida é a crecente e sofisticada ameaza cibernética que enfrontan as empresas hoxe en día. As Pemes, a miúdo, carecen de recursos e coñecementos especializados para protexerse eficazmente.

O meu proxecto aborda isto con a implementación dun sistema IDS/IPS con Suricata e Wazuh que responde directamente á necesidade crítica das organizacións de detectar e previr intrusiones en tempo real, minimizando o risco de violacións de datos e interrupcións de servizo, o uso de ferramentas *open source* como Suricata e Wazuh permite ofrecer unha solución de ciberseguridade robusta e avanzada que é economicamente máis accesible para pequenas e medianas empresas, democratizando o acceso a tecnoloxías que antes estaban restrinxidas a grandes corporacións, axudándose da integración con Wazuh centraliza non só as alertas de rede, senón tamén as de host, vulnerabilidades e monitorización de integridade, simplificando enormemente a xestión da seguridade e a análise de incidentes para administradores de sistemas que non son especialistas puros en ciberseguridade.

Tamén conta cunha protección proactiva, que é a capacidade do sistema de operar en modo IPS activo, bloqueando ameazas de forma automática, ofrece unha capa de protección proactiva esencial, que complementa a simple detección e reduce a carga de traballo manual cunha adaptabilidade de desenvolver posibles regras personalizadas que permite adaptar a seguridade ás necesidades específicas de cada empresa, ofrecendo unha defensa máis precisa fronte a ameazas dirixidas ou vulnerabilidades particulares dos seus sistemas e adicionalmente, o modelo de soporte técnico especializado 24/7 que se propón, resolve a carencia de persoal cualificado in-house en moitas empresas, garantindo unha resposta rápida e efectiva ante calquera incidente.

7.1. Problemas na execución do proxecto.

Os problemas atopados neste proxecto foron os seguintes:

- Complexidade da configuración de Suricata: Un dos primeiros desafíos foi a complexidade da configuración inicial de Suricata, especialmente a optimización do seu ficheiro `suricata.yaml` para un rendemento óptimo e a correcta captura do tráfico de rede.
- Solución: Isto solucionouse mediante unha lectura exhaustiva da documentación oficial, a consulta de foros especializados e a realización de múltiples probas iterativas con diferentes parámetros ata atopar a configuración máis axeitada para o noso ambiente de laboratorio.
- Tuning de regras e falsos positivos/negativos: A xestión e afinación das regras (especialmente as personalizadas) presentou o reto de minimizar os falsos positivos (alertas sobre tráfico lexítimo) e os falsos negativos (non detectar ameazas reais).
- Solución: Abordouse este problema mediante un proceso continuo de probas con diferentes tipos de tráfico (lexítimo e malicioso simulado) e un axuste meticuloso dos limiares e contidos das regras, aprendendo a priorizar as alertas máis relevantes.
- Integración entre Suricata e Wazuh: A correcta integración do pipeline de datos desde Suricata a Wazuh (a través de `eve.json` e o axente de Wazuh ou Filebeat) requiriu un estudo detallado dos formatos de log e das configuracións necesarias para que Wazuh interpretase correctamente os eventos de Suricata.
- Solución: Este desafío superouse consultando a documentación específica de integración de ambas as ferramentas e experimentando con diferentes parsers e decoders en Wazuh ata lograr que os datos se visualizasen e analizasen correctamente na interface de Kibana/Wazuh.
- Configuración do modo IPS: Pór Suricata en modo IPS activo e integralo co firewall do sistema foi un punto crítico, xa que calquera erro podería bloquear tráfico lexítimo ou comprometer a dispoñibilidade da rede de proba.
- Solución: Requiriu un coñecemento profundo das cadeas de iptables e unha planificación minuciosa da orde das regras. Realizáronse probas de illamento exhaustivas nun ambiente controlado para asegurar que o bloqueo se producise só para o tráfico malicioso e sen afectar as operacións normais.

7.2. Reflexión sobre o proxecto.

Adquirín experiencia práctica no despregamento, configuración e xestión de ferramentas open source de nivel empresarial como Suricata e Wazuh, comprendín a importancia crítica de ter un sistema de monitorización centralizado (SIEM) para a visibilidade completa da seguridade dunha infraestrutura, interpretar e traballar con logs de seguridade. Tamén aprendín que a necesidade de realizar probas iterativas e validar constantemente cada cambio para asegurar a funcionalidade desexada foi clave para evitar efectos non desexados.

8. Bibliografía, referencias e recursos utilizados

<https://docs.suricata.io/en/latest/>

<https://www.incibe.es/>

<https://www.boe.es/eli/es/rdl/2018/09/07/12>

<https://core.telegram.org/bots/api>

<https://documentation.wazuh.com/current/index.html>

<https://www.elastic.co/docs/get-started/the-stack>

<https://www.ige.gal/web/index.jsp?paxina=001&idioma=gl>

<https://ciberseguridadegalicia.gal/es>

<https://www.acelerapyme.gob.es/kit-digital>

<https://github.com/OpenSecureCo/Demos/blob/main/Telegram%20Integration>

9. Anexos
